



# **SEGURANÇA EM SISTEMAS DA INFORMAÇÃO**

---

wagner Johnatan da Silva

# 1. Introdução à Segurança da Informação

## Significado:

É o conjunto de práticas, tecnologias e processos desenhados para **proteger dados**, redes e sistemas de computadores contra acessos não autorizados, uso indevido, danos, modificações ou destruição. Não se trata apenas de "antivírus", mas de uma **cultura de proteção** da informação, seja ela digital ou física (no papel).



## Exemplo Prático:

Imagine a sua casa. Para protegê-la, você usa fechaduras nas portas (controle de acesso), câmeras de segurança (monitoramento) e, talvez, um **cofre** para documentos importantes (criptografia). A Segurança da Informação faz exatamente isso, mas no mundo digital, protegendo as "casas" (sistemas) e os "**cofres**" (bancos de dados) das empresas e das pessoas.





## 2. Importância da Segurança da Informação

**Significado:** Garantir a sobrevivência de negócios, proteger a privacidade e a intimidade das pessoas, além de evitar prejuízos financeiros, legais e de reputação. No cenário atual, onde os dados são considerados o "novo petróleo", perder informações ou ter o sistema sequestrado pode significar a falência de uma empresa ou um dano irreparável à vida de um indivíduo.



**Exemplo Prático:** Pense em um grande hospital. Se um ataque hacker paralisar o sistema deles, os médicos não conseguirão acessar os prontuários, alergias ou o histórico de medicamentos dos pacientes. Cirurgias podem ser canceladas e vidas colocadas em risco. A segurança da informação aqui não é apenas sobre "proteger computadores", é sobre proteger vidas.



# 3. Princípios Fundamentais (A Tríade CID)

Os princípios da Segurança da Informação são mundialmente conhecidos pela sigla CID (Confidencialidade, Integridade e Disponibilidade).

**Significado:** Garantir que a informação seja acessível apenas por pessoas, entidades ou processos autorizados. É a **proteção contra o vazamento de dados.**



**Exemplo:** O seu aplicativo de banco. A confidencialidade garante que apenas você (usando sua senha ou biometria) e os sistemas do banco consigam visualizar o saldo da sua conta, mantendo bisbilhoteiros de fora.



**Integridade:** Garantir a certeza de que você fez um PIX de R\$ 50,00 para nete da informação, protegendo-a contra alterações protegendo-a contra o sistema não altere o valor da transação, aguarante que não altere o valor da transação no meio do caminho (para R\$ 500,00, por exemplo) nem mude o destinatário o destinatário. O dado chega exatamente como saiu ao transmissor.



**Disponibilidade:** Garantir que: Exemplo: O sistema de vendas de um site de comércio eletrônico durante a Black Friday. Se o site "cair" devido a um ataque ou falha de servidor, a disponibilidade foi violada, gerando enorme prejuízo financeiro. A informação precisa estar lá quando requerida.







# 1. INTERFACE - Front-End

A camada visível e interativa com a qual o usuário interage diretamente. Responsável pela experiência do usuário (UX) e design.

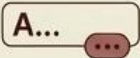


# 3. IMPORTÂNCIA DO FRONT-END NA SEGURANÇA

Front-end desempenha um papel crucial na redução da superfície de ataque e na proteção da experiência do usuário.



# RECURSOS DE SEGURANÇA E UX NO FRONT-END

| RECURSO                                                                                                                              | FUNÇÃO DE SEGURANÇA / UX                                                                                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
|  <b>Limite de Caracteres</b>                        | Previne ataques de Buffer Overflow (no nível de aplicação) e envios desnecessários de grandes volumes de dados.                                     |
|  <b>Campos Obrigatórios</b>                         | Garante que o estado da aplicação seja consistente antes do processamento.                                                                          |
|  <b>Máscaras de Entrada<br/>(Ex: CPF, Telefone)</b> | Garante a padronização e evita a inserção de caracteres especiais onde não deveriam existir.                                                        |
|  <b>Tipagem de Inputs</b>                           | Usar <code>&lt;input type="email"&gt;</code> ou <code>type="number"</code> ajuda o navegador a validar o formato antes mesmo do clique no "Enviar". |



## 2. PROTEÇÃO DA INFORMAÇÃO E SESSÃO

Aqui o foco é proteger o que o usuário vê e como ele interage com a conta dele.

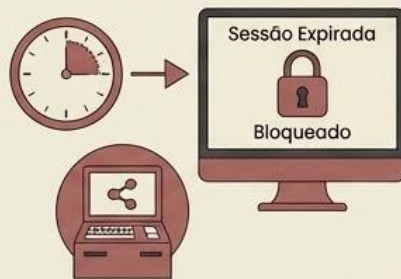
### Máscaras de Senha

Ocultar caracteres enquanto digita para evitar o shoulder surfing (alguém olhando por cima do ombro).



### Timeouts de Inatividade

Deslogar o usuário ou bloquear a tela após X minutos. Vital em computadores compartilhados.



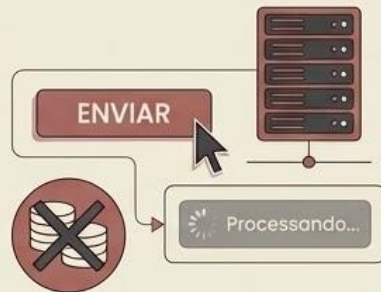
### Popups de Confirmação

Para operações sensíveis (ex: deletar conta, transferir dinheiro). Evita o "clique acidental" e protege contra UI Redressing.



### Desabilitar Botões após Clique

Evita o envio duplo de formulários, prevenindo duplicidade de transações financeiras ou sobrecarga no servidor.



# 3. RESILIÊNCIA E FEEDBACK (DEFENSIVE UI)

O sistema deve falhar de forma graciosa, sem expor as 'entranhas' do software.

## Páginas de Erro Customizadas

No front-end, nunca exibir o erro técnico (Stack Trace). Páginas 404/500 customizadas mantêm o usuário seguro e não dão pistas da tecnologia.



## Alertas de Lentidão/Loading

Se o sistema demora, feedback visual é vital. Evita ações repetitivas e mantém a confiança do usuário.



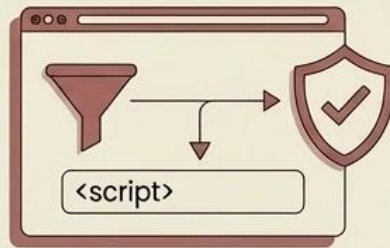
## CSP (Content Security Policy)

Política configurada via headers/meta tags que impede a execução de scripts maliciosos de terceiros.

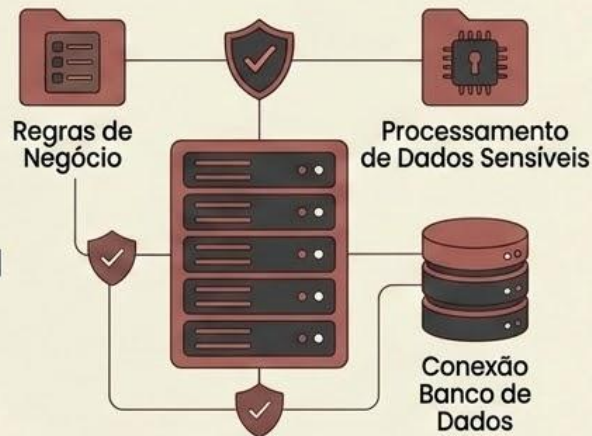


## XSS Protection

Filtros básicos no navegador que ajudam a proteger contra ataques de injeção de scripts (Cross-Site Scripting).



Enquanto a interface é o que o usuário vê, a estrutura (Back-End) é onde a mágica — e o perigo — a. É nesta camada que residem as regras de negócio, o processamento de dados sensíveis e a ponte com o banco de dados.

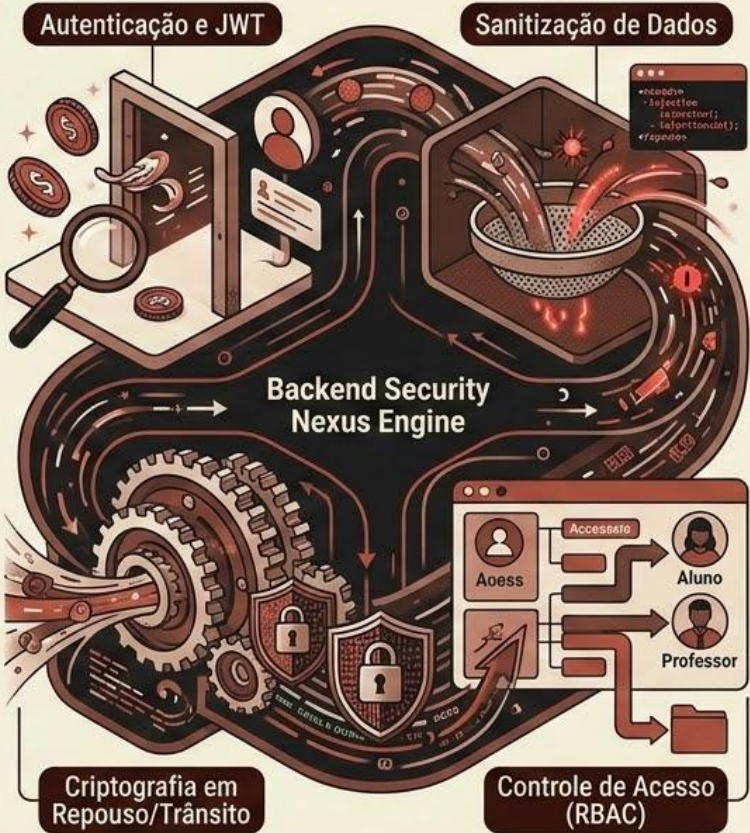


Significado: A segurança no Back-End foca em garantir que apenas comandos legítimos sejam processados, impedindo que invasores manipulem a lógica do sistema ou acessem informações privilegiadas.



# 3

Diferente do Front-End, onde as validações visam a experiência do usuário, aqui a validação é a última linha de defesa.



# Principais Ameaças e Defesas Estruturais

Além dos recursos específicos, o Back-End deve implementar defesas estruturais para garantir a integridade do sistema.

## 1. Prevenção de Injeção (SQL Injection)

**Ataque:** É o ataque onde o invasor tenta “enviar comandos” dentro de campos de texto comuns para ler ou apagar o banco de dados.

**Defesa:** Uso de Prepared Statements (Consultas Preparadas). O sistema trata o que o usuário digita estritamente como “texto” e nunca como “comando”.

## 2. Gestão de Erros no Lado do Servidor

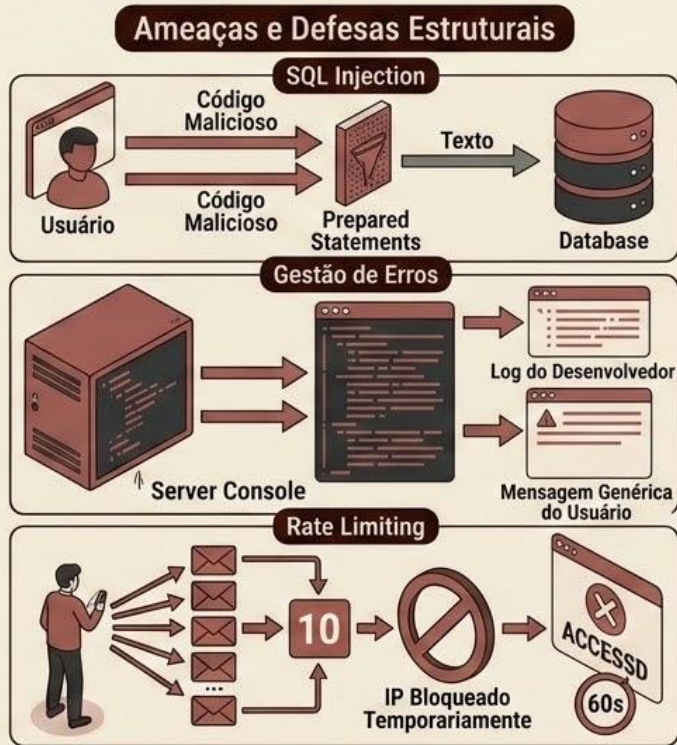
Logs detalhados para o desenvolvedor, mensagens genéricas para o usuário.

→ Exibir um erro técnico (Stack Trace) no navegador pode revelar a versão da sua linguagem de programação ou a estrutura das suas tabelas.

## 3. Rate Limiting (Limite de Requisições)

Evita que robôs ou usuários mal-intencionados tentem adivinhar senhas (ataque de força bruta) fazendo milhares de tentativas por segundo.

Se um mesmo IP tentar logar 10 vezes em um minuto, o Back-End bloqueia temporariamente aquele acesso.





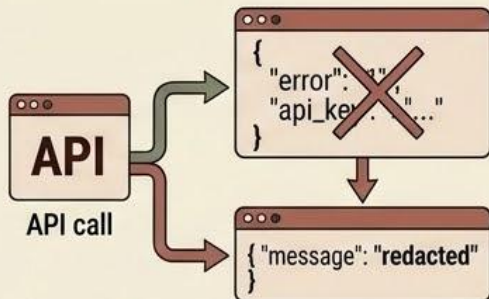
# 4. A Tríade CID no Back-End



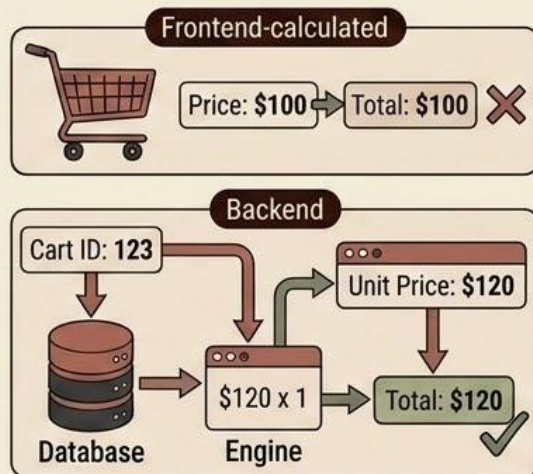
## Confidencialidade



Garantir que o código do Back-End não vaze chaves de API ou segredos do sistema em respostas de erro.



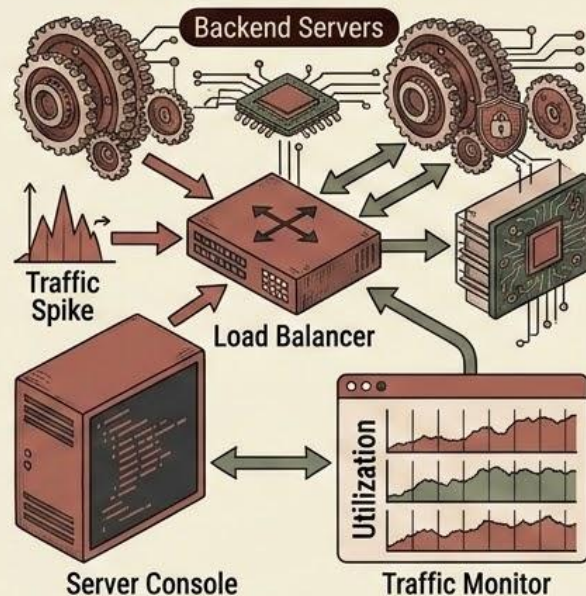
## Integridade



Validar os cálculos no servidor (Ex: nunca confiar no preço total enviado pelo Front-End; o Back-End deve calcular o valor real com base no banco de dados).



## Disponibilidade



Implementar balanceamento de carga para que o processamento pesado não derrube o servidor.



# 4. Conceitos Fundamentais de Segurança

## Comparação de JWT e SQL Injection

### JWT (JSON Web Token)



**Foco Principal:**  
Autenticação  
(Quem é você?)

**Analogia:** O crachá de uma conferência que te dá acesso às salas.



### SQL Injection

**Foco Principal:**  
Integridade  
(O dado é seguro?)

**Analogia:** Um vilão tentando dar ordens ao guarda fingindo que é parte de um formulário.



# 5. Autenticação com JWT



Login



O aluno insere usuário e senha.



Emissão



Se os dados estiverem certos, o Back-End cria um token e o envia para o navegador.

3

Uso



A cada nova ação (como ver notas), o navegador envia esse crachá de volta.



Validação



O servidor olha para o crachá e verifica a assinatura digital. Se ninguém alterou o texto, o acesso é liberado.

## A Estrutura do JWT:



Header



Payload



Signature

# Header/Payload/Signature



Diz qual algoritmo de proteção está sendo usado isado.



Contém os dados (Ex: "ID do Aluno: 123"). Cuidado: Não coloque senhas aqui, pois qualquer um pode ler o conteúdo, embora não possa alterá-lo.

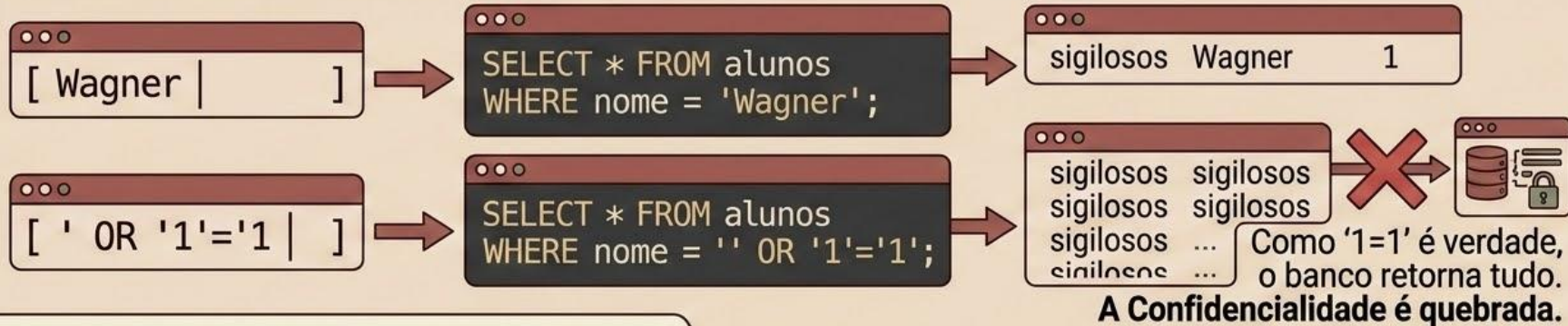


É o lacre de segurança. Só o seu servidor tem a "chave mestra" para gerar esse lacre.



# 2. Injeção de SQL (SQL Injection)

## 🛡️ O Ataque ("Aluno Espertinho")



## 🛡️ A Defesa (Prepared Statements)



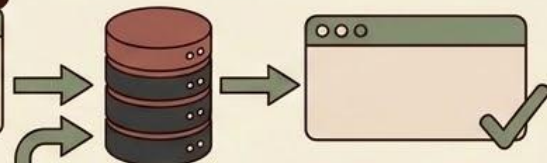
**Analogia:** Um formulário físico onde você escreve dentro de quadradinhos. O caixa (BD) só lê o que está dentro do quadrado.

### [ Molde do Comando SQL ]

```
SELECT * FROM alunos
WHERE nome = ?;
```

### [ Dados Separados ]

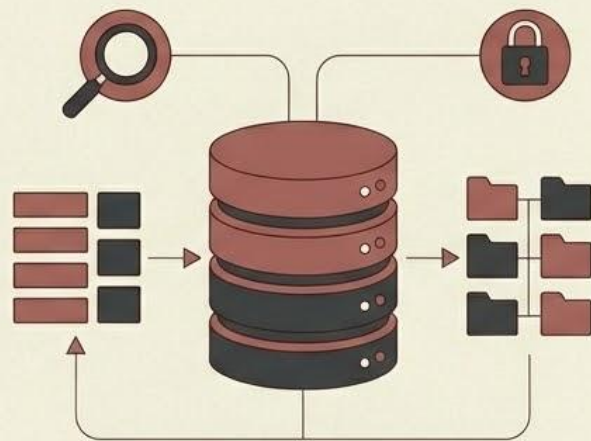
```
' OR '1'='1
```



**Prática:** Back-End envia o molde primeiro. O banco entende que aquilo é apenas um nome, mesmo com caracteres estranhos.

# 3. ARMAZENAMENTO - Banco de Dados

Onde as informações são guardadas de forma organizada e segura. Permite a persistência, recuperação e gerenciamento eficiente dos dados.

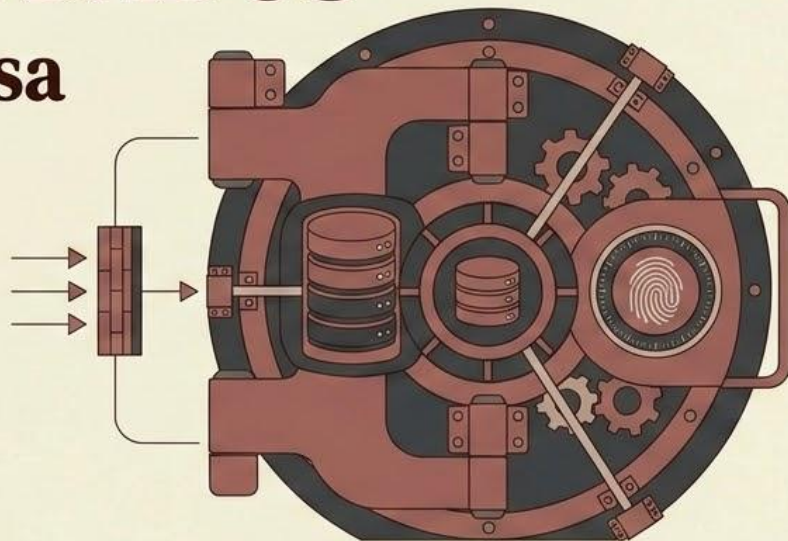




# 3. SEGURANÇA ESTRUTURAL NO BANCO DE DADOS

## A Última Fronteira de Defesa

Se o front-end e o back-end falharem,  
a segurança do banco de dados é o  
que impede o desastre total.  
Se os dados são o novo petróleo, o  
banco é o cofre principal da sua  
empresa.



**Criptografia na Origem:**  
Proteger dados antes de  
entrarem no banco.



**Controle de Acesso Granular:**  
Minimizar privilégios  
de usuários e sistemas.



**Monitoramento e Auditoria:**  
Rastreabilidade total de  
quem acessa e altera dados.

# A TRÍADE CID NO BANCO DE DADOS

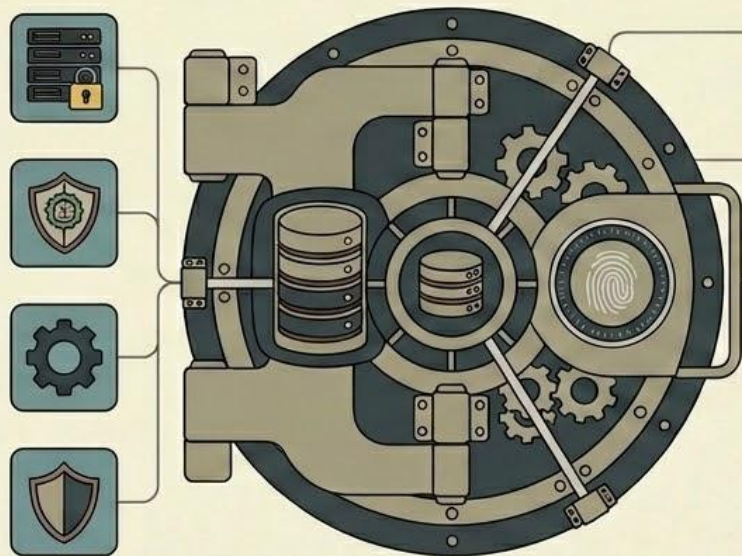
Os princípios fundamentais da segurança (Confidencialidade, Integridade e Disponibilidade) se aplicam rigorosamente aqui:





# RECURSOS DE SEGURANÇA NO ARMAZENAMENTO

Abaixo estão as principais práticas e ferramentas para proteger a camada de dados:



DATA



1030  
R20342  
018000  
058200  
010100  
CIPHER TEXT

## Criptografia em Repouso (Data at Rest)

Protege os arquivos físicos do banco. Se um invasor copiar os arquivos do servidor, levará apenas dados ilegíveis sem a chave de descriptografia.

password



HASHING o/ SALT  
(bcrypt)

66d2602e623a29  
67386335353596

## Hashing de Senhas

O banco nunca deve armazenar senhas em texto puro. Deve-se usar algoritmos de Hash (como bcrypt) com Salt para proteger as credenciais dos usuários em caso de vazamentos.



ADMINISTRADOR  
(Root)

## Princípio do Menor Privilégio

O sistema Back-End não deve se conectar ao banco de dados usando o usuário "Administrador" (Root). Ele deve ter um usuário restrito que só pode executar ações específicas necessárias para a aplicação.



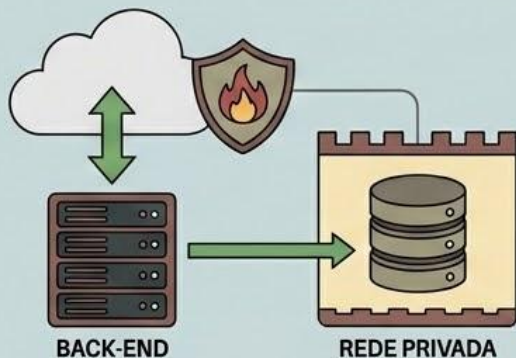
## Mascaramento de Dados (Data Masking)

Ocultar dados sensíveis de usuários que não precisam vê-los por completo (ex: desenvolvedores testando o sistema visualizam apenas os últimos 4 dígitos do cartão de crédito).

# PRINCIPAIS DEFESAS ESTRUTURAIS

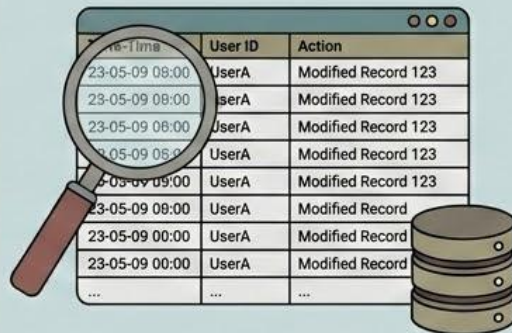
Além dos recursos diretos, a infraestrutura que envolve o banco precisa de regras de negócio estritas:

## 1. ISOLAMENTO DE REDE



O banco de dados nunca deve ser acessível diretamente pela internet. Ele deve estar contido em uma rede privada, aceitando conexões exclusivamente do servidor Back-End autorizado.

## 2. AUDITORIA E LOGS



Manter um registro detalhado de quem acessou, modificou ou deletou informações críticas. Se ocorrer um vazamento, os logs do banco de dados são fundamentais para a investigação (análise forense).

## 3. ROTINAS DE BACKUP TESTADAS



Não basta fazer o backup, é preciso garantir que ele funciona. Cópias de segurança devem mantidas em ambientes separados e imutáveis, sendo a principal defesa contra ataques de sequestro de dados (Ransomware).



# 4. INFRAESTRUTURA - Operações

O alicerce tecnológico que sustenta todo o sistema. Inclui servidores, redes, nuvem e ferramentas de monitoramento e implantação.

